

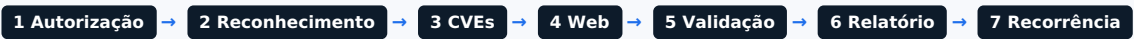
O Processo de Scan, Etapa por Etapa

O que acontece desde a URL inserida até o relatório entregue — e o que observar em cada passo

Documento de apoio • Complemento ao Blueprint de Produto • Outubro de 2026

Como ler

Cada etapa mostra quatro coisas: **o que entra**, **o que a etapa faz**, **o que sai** e um ponto de **atenção**. A saída de uma etapa é a entrada da seguinte — é essa cadeia que o agente orquestra automaticamente.



1 Onboarding e autorização

Etapa 1 de 7

Ferramenta: Sua plataforma (não uma ferramenta de ataque)

O QUE ENTRA
A URL ou domínio que o cliente quer testar.

O QUE A ETAPA FAZ
Confirma que o alvo pertence ao cliente (ex.: registro DNS TXT) e define o escopo autorizado — o que pode e o que não pode ser tocado.

O QUE SAI
Um alvo validado e um escopo travado no sistema.

ATENÇÃO
Sem autorização formal, testar um site é crime. Esta etapa é a barreira legal — e não é opcional.

2 Reconhecimento

Etapa 2 de 7

Ferramenta: naabu (licença MIT — embutível)

O QUE ENTRA
O domínio autorizado.

O QUE A ETAPA FAZ
Mapeia portas abertas e serviços expostos — descobre a superfície de ataque real (o que está de fato acessível na internet).

O QUE SAI
Lista de serviços vivos: portas, protocolos, versões.

ATENÇÃO
Alvos atrás de CDN/WAF podem esconder a origem real; o resultado reflete o que está exposto, não tudo que existe.

3 Varredura de CVEs

Etapa 3 de 7

Ferramenta: nuclei (licença MIT — embutível)

O QUE ENTRA
Os serviços e versões achados no reconhecimento.

O QUE A ETAPA FAZ
Compara cada serviço contra milhares de templates de vulnerabilidades conhecidas (CVEs), senhas padrão e configurações erradas.

O QUE SAI
Lista de candidatos a falha, cada um ligado a um template.

ATENÇÃO
Aqui aparece o grosso do "básico". Ainda são candidatos — alguns podem ser falso-positivo até a validação confirmar.

4

Teste de aplicação web

Etapa 4 de 7

Ferramenta:

OWASP ZAP (via API) (licença Apache 2.0 — embutível)

O QUE ENTRA

A URL da aplicação e as rotas descobertas.

O QUE A ETAPA FAZ

Rastreia o site a partir da URL e testa cada rota: injeções, falhas de autenticação, cabeçalhos de segurança ausentes, itens do OWASP Top 10.

O QUE SAI

Achados na camada de aplicação, com a requisição que os expôs.

ATENÇÃO

Áreas atrás de login só são testadas se o cliente fornecer credenciais de teste. Lógica de negócio complexa foge do escopo do produto básico.

5

Validação

Etapa 5 de 7

Ferramenta:

Lógica própria (seu diferencial — não é ferramenta de terceiros)

O QUE ENTRA

Todos os candidatos a falha das etapas anteriores.

O QUE A ETAPA FAZ

Confirma cada achado com uma prova concreta sempre que possível, descarta falso-positivo e classifica a severidade (crítico a baixo).

O QUE SAI

Achados confirmados e priorizados, com evidência reproduzível.

ATENÇÃO

É a etapa que protege a confiança no produto. Validar sem causar dano ao ambiente do cliente é a regra de ouro.

6

Relatório e remediação

Etapa 6 de 7

Ferramenta:

Lógica própria + LLM (seu diferencial)

O QUE ENTRA

Os achados confirmados e priorizados.

O QUE A ETAPA FAZ

Traduz a trilha técnica em linguagem clara: o que é, por que importa e o passo-a-passo para corrigir — para um dev ou gestor entender.

O QUE SAI

Relatório acionável, mapeado a severidade e ao OWASP.

ATENÇÃO

O valor não é um relatório bonito; é uma correção que o cliente consegue executar sem ser especialista.

7

Recorrência

Etapa 7 de 7

Ferramenta:

Agendador + estado por cliente

O QUE ENTRA

O histórico de scans anteriores do mesmo alvo.

O QUE A ETAPA FAZ

Reexecuta o fluxo (agendado, por deploy ou quando surge um CVE novo) e compara com o passado.

O QUE SAI

"3 falhas novas, 5 corrigidas desde o último scan" — a evolução ao longo do tempo.

ATENÇÃO

É o que transforma um relatório pontual em assinatura recorrente — o coração do modelo de negócio.

Três leituras do fluxo

Etapas 1 é a fronteira legal: tudo que vem depois só é permitido porque o alvo foi verificado. **Etapas 2 a 4** são a cobertura do "80% comum", todas sobre bibliotecas permissivas e embutíveis. **Etapas 5 e 6** são onde está o diferencial do produto — validação e relatório para leigos são lógica própria, a sua propriedade intelectual.

Documento de apoio ao Blueprint de Produto. As técnicas descritas devem ser usadas apenas sob autorização formal e dentro de escopo contratado.